

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-21 09:00 WIB

Top 5 Highlights

- ISC Stormcast For Tuesday, July 21st, 2026 <https://isc.sans.edu/podcastdetail/10016>, (Tue, Jul 21st)
- Estée Lauder discloses data breach via Oracle E-Business flaw
- SonicWall SMA1000 flaws exploited as zero-days to push custom malware
- 'WP2Shell' Opens Millions of WordPress Sites to Remote Takeover
- Cursor, Codex, Gemini CLI, Antigravity hit by sandbox escapes

Threat Intelligence (10)

01. ISC Stormcast For Tuesday, July 21st, 2026

<https://isc.sans.edu/podcastdetail/10016>, (Tue, Jul 21st)

ISC Stormcast For Tuesday, July 21st, 2026 <https://isc.sans.edu/podcastdetail/10016>, (Tue, Jul 21st)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33170>

02. HollowGraph malware uses Microsoft 365 calendar for command and control

HollowGraph, believed to be part of the Cavern command-and-control framework, targets organizations in Israel for espionage purposes.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/hollowgraph-malware-uses-microsoft-365-calendar-for-command-and-control>

03. Attackers Combo Up Evasion Tactics for BEC Phishing

"The TFF Trap" uses fileless techniques and loaders with low detection rates to deploy various RATs and stealers, including Agent Tesla, Remcos, XWorm, and Best Private Logger.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.darkreading.com/endpoint-security/attackers-combo-evasion-tactics-bec-phishing>

04. FakeGit Campaign Uses 7,600 GitHub Repositories to Spread SmartLoader Malware

Cybersecurity researchers have discovered nearly 7,600 malicious GitHub repositories, out of which more than 800 pose as artificial intelligence (AI) skills or Model Context Protocol (MCP) servers to deliver a malware family known as SmartLoader as part of an ongoing campaign codenamed FakeGit. "FakeGit uses copied projects, lookalike developer profiles, co...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/fakegit-campaign-uses-7600-github.html>

05. Exposed Server Reveals AI-Assisted Phishing Toolkit Behind WebDAV Malware Campaign

A malware operator left its delivery server wide open, and Rapid7 pulled down the whole toolkit: 1,048 files spanning lure templates, filename-spoofing tests, execution experiments, droppers, builder notes, and two campaign chains. One was already live against Windows users in Mexico, delivering an infostealer through a fake government ID-lookup site over W...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/07/exposed-server-reveals-ai-assisted.html>

06. HOLLOWGRAPH malware turns Microsoft 365 calendars into an espionage channel

Microsoft 365 calendars have become a hiding place for espionage malware, with commands and stolen files stashed inside appointments dated to the year 2050, researchers from Group-IB discovered. Targeted campaign tied to Iranian espionage activity The malware, which Group-IB calls HOLLOWGRAPH, is one component of a bigger toolkit the company links with high...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.helpnetsecurity.com/2026/07/20/hollowgraph-malware-microsoft-365-calendar/>

07. New HollowGraph Malware Hijacks Microsoft 365 Calendars for Covert C2 Communications

Researchers have linked HollowGraph malware to the Cavern framework after discovering its use of Microsoft 365 calendars and Microsoft Graph APIs as a stealthy C2 channel

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/hollowgraph-microsoft-calendars/>

08. Fake games spread stealers with RenPy Loader, MSBuild and EtherHiding

We look into how attackers are using the legitimate Ren'Py game engine to spread a malware loader that ultimately delivers Amatera Stealer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/07/fake-games-spread-stealers-with-renpy-loader-msbuild-and-etherhiding>

09. [+24h Old] SleeperGem Uses Three Malicious RubyGems Packages to Target Developer Machines

Cybersecurity researchers have flagged a new software supply chain attack codenamed SleeperGem targeting the Ruby ecosystem after three malicious gems were published to RubyGems with the end goal of serving additional payloads. The rogue gems are listed below - `git_credential_manager` (versions 2.8.0, 2.8.1, 2.8.2, 2.8.3) - Published on July 18, 2026 Dendreo...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/07/sleepergem-uses-three-malicious.html>

10. [+24h Old] A forensic tool for backdoored code completions in AI assistants

Developers lean on AI coding assistants for a growing share of their daily work, letting the tools predict the next few lines and accepting many suggestions with a quick glance. Those tools learn from large collections of code, and some of that code can be tampered with before training starts. A poisoned example teaches a model to write insecure code when i...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.helpnetsecurity.com/2026/07/20/tracing-backdoored-code-completions/>

Latest Vulnerabilities (10)

01. Estée Lauder discloses data breach via Oracle E-Business flaw

Cosmetics giant Estée Lauder is notifying customers of a data breach after hackers exploited a flaw in Oracle E-Business Suite that the company used for human resources (HR) operations. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/est-e-lauder-discloses-data-breach-via-oracle-e-busines-flaw/>

02. SonicWall SMA1000 flaws exploited as zero-days to push custom malware

Two recently disclosed SonicWall SMA1000 vulnerabilities were exploited in zero-day attacks for weeks, allowing threat actors to install custom malware on vulnerable VPN appliances. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/sonicwall-sma1000-flaws-exploited-as-zero-days-to-push-custom-malware/>

03. 'WP2Shell' Opens Millions of WordPress Sites to Remote Takeover

Barely three days after disclosure, attackers are widely chaining together CVE-2026-60137 and CVE-2026-63030 to lob exploit attempts against one of the largest attack surfaces on the Internet.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/wp2shell-millions-wordpress-sites-remote-takeover>

04. Cursor, Codex, Gemini CLI, Antigravity hit by sandbox escapes

Researchers escaped the sandboxes in Cursor, Codex, Gemini CLI and Antigravity by having the AI agent write files that trusted host tools later run. Multiple CVEs, patches, and Google downgrading two Antigravity findings. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cursor-codex-gemini-cli-antigravity-hit-by-sandbox-escapes/>

05. F5 fixes critical nginx vulnerability CVE-2026-42533

The vulnerability, with a CVSS score of 9.2, allows an unauthenticated attacker to trigger a heap buffer overflow by sending specially crafted HTTP requests.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/f5-fixes-critical-nginx-vulnerability-cve-2026-42533>

06. ServiceNow's sandbox escape RCE hole now exploited in the wild

A sandbox security hole that could lead to remote code execution (RCE), patched last week by ServiceNow, is being actively exploited in the wild, according to a report from threat intel firm Defused...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4198993/servicenows-sandbox-escape-rce-hole-now-exploited-in-the-wild.html>

07. WordPress Exploitation Underway (CVE-2026-63030), (Mon, Jul 20th)

Last week, Searchlight Cyber released details about a vulnerability they are calling "wp2shell". The vulnerability was initially announced without a CVE number. But now has been assigned CVE-2026-63030. Many WordPress plugin vulnerabilities are never assigned CVE numbers. But wp2shell is different. It is a SQL injection vulnerability in WordPress Core, not...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://isc.sans.edu/diary/rss/33168>

08. AI adoption and business acceleration are changing the expectations of technology risk management

As AI becomes embedded in customer experiences, internal workflows, and throughout the supply chain, security leaders are being asked to do more than manage risk. They are being asked to help the business make more informed decisions and move faster. At the same time, AI has evolved faster than the programs built to govern it. The result is a widening gap b...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4198872/ai-adoption-and-business-acceleration-are-changing-the-expectations-of-technology-risk-management.html>

09. ServiceNow pre-auth RCE exploited in the wild (CVE-2026-6875)

Attackers have begun exploiting CVE-2026-6875, a critical pre-authentication vulnerability in the ServiceNow AI Platform, according to threat intelligence firm Defused. About the vulnerability ServiceNow AI is a Platform-as-a-Service that lets organizations build and automate digital workflows. CVE-2026-6875 is a code injection vulnerability that lets unaut...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/20/servicenow-cve-2026-6875-exploited/>

10. SonicWall Zero-Days Exploited to Deliver Custom Malware for Weeks Before Patch

The zero-days CVE-2026-15409 and CVE-2026-15410 were exploited by a threat actor tracked by Volexity as UTA0533. The post SonicWall Zero-Days Exploited to Deliver Custom Malware for Weeks Before Patch appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/sonicwall-zero-days-exploited-to-deliver-custom-malware-for-weeks-before-patch/>

Data Breach & Cybercrime (10)

01. JadePuffer agentic attacks now target AI model data with ransomware

The JadePuffer autonomous AI agent has upgraded with custom malware called EncForge that focuses on encrypting AI assets, such as training datasets, vector databases, and model checkpoints. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/jadepuffer-agentic-attacks-now-target-ai-model-data-with-ransomware/>

02. Ecopetrol confirms ransomware attempt, data stolen from 3,300 accounts

The incident involved an unidentified threat actor accessing Ecopetrol's IT infrastructure and exfiltrating pseudonymous data from 3,300 user accounts.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/brief/ecopetrol-confirms-ransomware-attempt-data-stolen-from-3300-accounts>

03. Craneware confirms customer and employee data exposed in security incident

The breach, which occurred on July 20, saw a significant volume of file names viewed and exfiltrated by unauthorized individuals.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/craneware-confirms-customer-and-employee-data-exposed-in-security-incident>

04. The Odyssey piracy scams surface hours after its theatrical debut

Christopher Nolan's *The Odyssey* had barely reached theaters before scammers began targeting people searching for pirated copies, according to Malwarebytes. Within hours of the film's release, researchers found two separate scams running on cloned piracy sites: fake browser warnings and Windows executables disguised as movie downloads. "Neither scam has anyt...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/20/odyssey-movie-piracy-scams-malware/>

05. New HollowGraph malware uses Microsoft Graph for stealthy C2 comms

A malicious component dubbed HollowGraph uses the calendar feature in compromised Microsoft 365 mailboxes as a command-and-control channel to receive attacker commands and exfiltrate stolen data. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/new-hollowgraph-malware-uses-microsoft-graph-for-stealthy-c2-comms/>

06. The Odyssey piracy scams appear within hours of the movie's release

The release of *The Odyssey* has already sparked a wave of piracy scams, from fake browser errors to malware masquerading as movie files.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/07/the-odyssey-piracy-scams-appear-within-hours-of-the-movies-release>

07. Paidwork breach exposes sensitive data of 23 million user

Data belonging to more than 23 million users has been exposed following a breach at Paidwork, a platform that pays people for completing online microtasks. Paidwork markets itself as a way to earn money through simple tasks like watching ads, testing apps, and completing surveys, with most jobs paying only a few cents at a time. For its users, many of whom...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/20/paidwork-data-breach-23-million-users/>

08. HollowGraph Malware Hides C2 and Stolen Files in Microsoft 365 Events Dated 2050

A newly discovered espionage implant has been using a hijacked Microsoft 365 calendar as its command channel, planting operator instructions and smuggling out stolen files as attachments on calendar events dated to the year 2050. Group-IB, which named the malware HollowGraph, says the approach moves tasking and stolen data through legitimate Microsoft Graph...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/07/hollowgraph-malware-hides-c2-and-stolen.html>

09. Healthcare giant Abbott probes two cyber incidents amid extortion claims

Extortion groups ShinyHunters and ShadowByt3\$ claim they stole vast amounts of patient data. Those allegations have not been verified.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/data-breaches/2026/07/healthcare-giant-abbott-probes-two-cyber-incidents-amid-extortion-claims>

10. JadePuffer Returns With Ransomware Designed to Wipe AI Models

JadePuffer follow-up campaign deployed ENCFORGE locker built to destroy AI model artifacts

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/jadepuffer-ai-model-ransomware/>